



# SNOWBE ONLINE SECURITY PLAN

**Created By:**

Jarred Ward

**Version 4.0**

**Date:** 03/29/2026

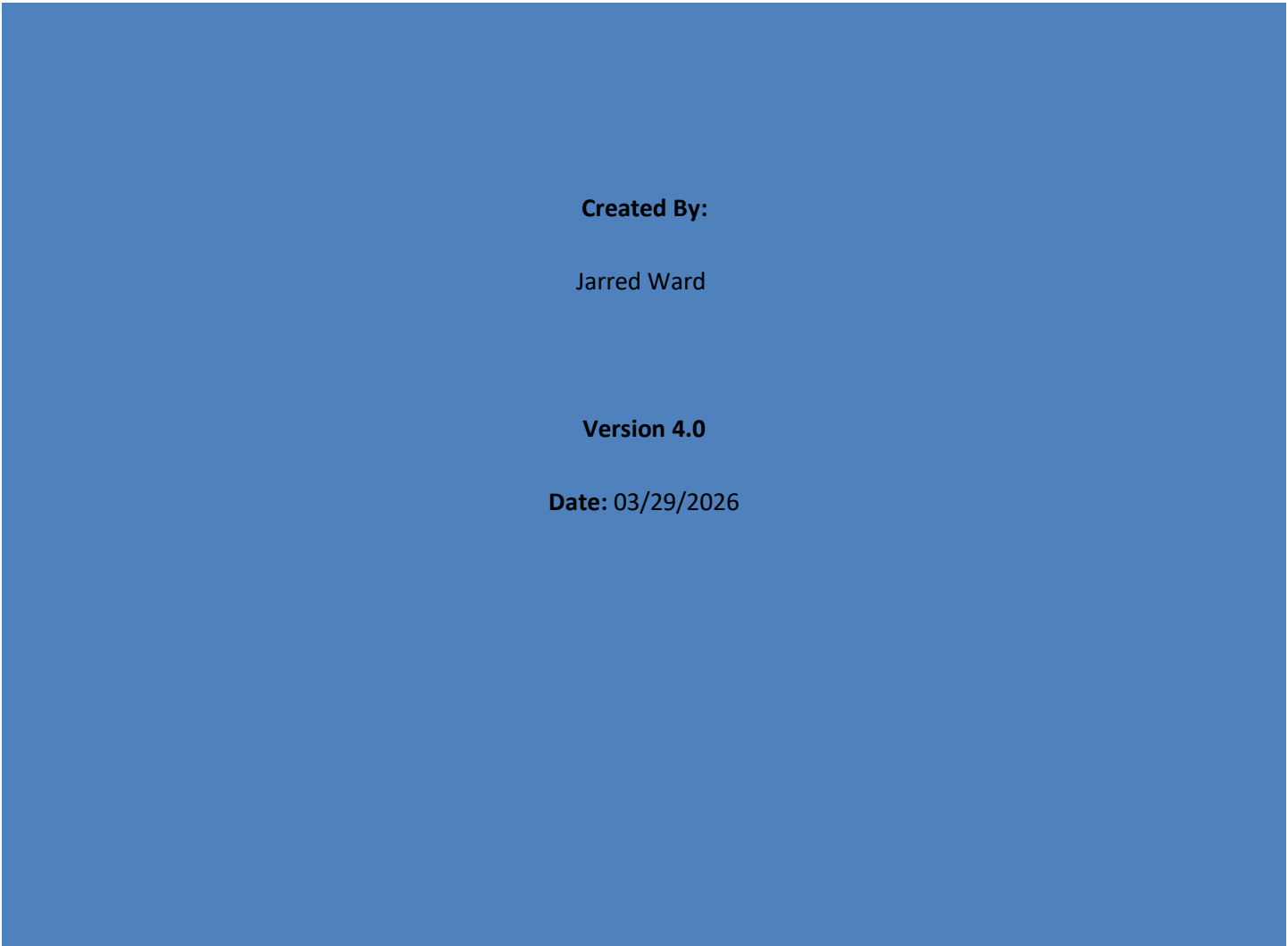


Table of Contents

Section 1: Introduction.....2

Section 2: Scope .....2

Section 3: Definitions .....2

Section 4: Roles & Responsibilities .....4

Section 5: Statement of Policies, Standards and Procedures .....5

    Policies..... 5

    Standards and Procedures ..... 9

Section 6: Exceptions/Exemptions.....10

Section 7: Version History Table .....10

Citations .....10

## **Section 1: Introduction**

The purpose of SnowBe Online's Security Plan is to protect the company's data, systems, and customers from unauthorized access, misuse, or loss. As SnowBe expands and prepares to go public, formal security rules and controls are necessary to prevent data breaches, service interruptions, and the compromise of sensitive information. This plan helps safeguard credit card data, personal details, and order histories while ensuring compliance with recognized security frameworks such as NIST SP 800-53 and PCI DSS. It defines standards for protecting SnowBe Online's digital and physical assets, maintaining regular updates and backups, limiting access to sensitive information, and promoting awareness of security responsibilities throughout the organization. By following this plan, SnowBe Online will strengthen customer trust, maintain compliance with regulations, and support secure business growth across both e-commerce and retail operations. The plan will be reviewed and updated annually or whenever significant changes occur.

## **Section 2: Scope**

This plan applies to all SnowBe Online employees, contractors, vendors, and third-party partners who access or manage company information systems. It covers all data, software, applications, and hardware used within SnowBe's corporate offices, retail locations, and AWS-hosted environments. The plan also governs the handling of customer information collected through SnowBe Online's website and in-store payment systems to ensure consistent protection and responsible use across all business operations.

## **Section 3: Definitions**

### **Access Control**

The method of regulating who can view, modify, or use information resources, ensuring that only authorized individuals can access SnowBe's systems and data.

### **Authentication**

Authentication is the process of verifying a user's identity before granting access to SnowBe resources.

### **Authorization**

Authorization is the determination of what an authenticated user is permitted to do within a system.

### **Availability**

The assurance that information and system resources are accessible and usable upon demand by authorized users, processes, or devices.

## **Baseline Security Requirements**

The minimum required security controls, design expectations, and protection measures that must be addressed for a system before approval and deployment.

## **Confidentiality**

Ensuring that information is accessible only to those authorized to have access.

## **Cryptographic Key Management**

The administrative and technical process of generating, distributing, storing, rotating, and revoking encryption keys used to protect data. Strong key management ensures confidentiality and prevents unauthorized decryption of sensitive customer and payment information.

## **Encryption**

The process of transforming readable data into an unreadable format using cryptographic algorithms.

## **Integrity**

Safeguarding the accuracy and completeness of information and processing methods.

## **Least Privilege**

Least privilege is a security principle requiring that users receive the minimum level of access needed to perform their job functions, reducing the risk of accidental or malicious misuse of SnowBe systems.

## **Maturity Model**

A structured framework used to evaluate and measure the effectiveness and progression of security practices.

## **Multi-Factor Authentication (MFA)**

A security method that requires a user to provide two or more independent forms of verification before gaining access to a system.

## **Personally Identifiable Information (PII)**

Information which can be used to distinguish or trace an individual's identity, such as their name or Social Security number, or other linked identifying data.

## **Risk**

The likelihood of a threat taking advantage of vulnerability and the resulting business impact.

## **Risk Assessment**

The process of identifying threats, vulnerabilities, likelihood, impact, and overall risk to organizational systems or data.

**Security Misconfiguration**

A vulnerability caused by improper or incomplete configuration of systems, applications, cloud services, or security controls.

**System Development Life Cycle (SDLC)**

A structured approach used to guide a system from concept through planning, design, implementation, operation, maintenance, and retirement while addressing security requirements throughout.

**VPN (Virtual Private Network)**

A secure communication tunnel that encrypts traffic to protect data in transit between devices and a network. VPN access is required for remote employees to ensure secure authentication, confidentiality, and integrity

**Vulnerability**

A weakness of an asset or group of assets that can be exploited by one or more threats to compromise the confidentiality, integrity, or availability of information or systems.

## **Section 4: Roles & Responsibilities**

**Access Control Administrator**

Responsible for creating, modifying, disabling, and removing user accounts in accordance with approved requests.

**Chief Information Security Officer (CISO)**

The CISO oversees SnowBe's information security strategy, ensuring alignment with business goals, NIST 800-53 controls, and PCI DSS compliance. This role oversees risk management, security governance, and coordination of security operations across all departments.

**Cloud Systems Administrator**

manages cloud-based infrastructure, including identity roles, encryption settings, storage configurations, and monitoring services. This role maintains cloud security baselines and enforces approved access permissions.

**Compliance Officer**

Oversees adherence to PCI DSS, internal policies, and external regulatory standards. This role ensures vendors, payment systems, and internal processes meet required controls.

**Developer**

Builds, configures, and maintains systems in accordance with security requirements while remediating vulnerabilities and supporting secure implementation practices.

### **Incident Response Coordinator**

Leads the identification, containment, and resolution of security incidents. This role documents findings, coordinates response actions, and ensures proper communication during incidents.

### **IT Security Manager**

Oversees SnowBe's security operations and ensures policies and controls are properly implemented. This role coordinates vulnerability management, monitors alerts, and guides remediation efforts.

### **Network Security Administrator**

manages firewalls, VPN gateways, and network segmentation to secure internal and external communications. This role monitors network activity and enforces boundary protection standards.

### **Project Manager**

Coordinates planning, timelines, and deliverables while ensuring required security activities, reviews, and approvals are completed throughout the lifecycle.

### **Security Awareness & Training Coordinator**

Responsible for developing, delivering, and tracking security training for all personnel. This role ensures staff understand organizational policies, regulatory requirements, and secure practices.

### **System Administrators**

Maintains and secures on-premises servers, workstations, and endpoint devices. This role applies patches, manages configurations, and ensures endpoints follow approved security standards.

## **Section 5: Statement of Policies, Standards and Procedures**

### **Policies**

#### **AC-02 Account Management**

This policy defines how user accounts are created, managed, and removed, to make sure that only authorized individuals have access to SnowBe Online's systems and data.

#### **AC-03 Access Enforcement**

This policy will define and enforce access controls to make sure that users and systems only access the necessary, authorized data.

#### **AC-04 Information Flow enforcement**

Ensures that SnowBe approves and enforces how information flows within and between its systems. It protects sensitive company and consumer information from unauthorized access or exposure.

**AC-05 & AC-06 Separation of Duties & Least Privilege**

These policies ensure that SnowBe Online limits user access and divides responsibilities, so no single employee can perform or approve all critical actions.

**AC-07 Unsuccessful Logon Attempts**

This policy limits the number of failed login attempts allowed before an account is locked to reduce the risk of brute-force or unauthorized access.

**AC-11 & AC-12 Device Lock & Session Termination**

These policies protect SnowBe's systems by automatically locking unattended devices and terminating inactive sessions to prevent unauthorized access to sensitive data.

**AC-16 Security and Privacy Attributes**

This policy will help to apply security and privacy attributes to all sensitive customer data and payment information. These attributes will help to ensure proper encryption, access restrictions, and compliance.

**AC-17 Remote Access**

This policy will require all remote connections to SnowBe Online systems and data to be secure, authenticated, and encrypted to protect company assets and consumer data.

**AC-18 Wireless Access**

Requires organizations to control, authenticate, and protect wireless network connections to prevent unauthorized or insecure wireless access.

**AC-19 Access Control for Mobile Devices**

This policy establishes security requirements for connecting, managing, and using mobile devices to ensure they access SnowBe resources safely and in compliance with organizational controls.

**AC-21 Information Sharing**

This policy controls how information is shared inside and outside the company, to keep customer and payment data safe and secure.

**AC 24 Access Control Decisions**

The Access control Decisions policy demands all access to SnowBe's systems be verified as authorized or unauthorized based on IAM security policies enforced by SnowBe Online.

**AC-25 Reference Monitor**

Ensures that all access requests are mediated by a trusted, tamper-resistant reference monitor that cannot be bypassed or altered.

### **ACP-03 New Account Creation Procedure**

Establishes the authorized, repeatable workflow for creating new SnowBe user and service accounts, ensuring proper identity verification and role-appropriate access.

### **CC-01 Cloud Configuration**

This policy establishes standards for securely configuring and monitoring SnowBe Online's cloud environments to prevent misconfigurations, protect data, and maintain compliance.

### **CCM-03 Change Control Management**

Defines the structured process for requesting, evaluating, approving, and implementing changes to SnowBe's systems and infrastructure.

### **CP-09 System Backup**

Customer and payment data must be backed up regularly, tested for recovery, and protected with encryption at rest and in transit.

### **DBR-01 Data Backup and Recovery**

This policy defines SnowBe Online's procedures for regularly backing up critical data and systems, and outlines recovery processes to ensure business continuity during system disruption.

### **DR-01 Data Retention and Disposal**

This policy establishes how SnowBe Online retains necessary business and customer data for defined periods and securely destroys it when no longer needed.

### **ED-01 Education/Training**

This policy requires all SnowBe Online employees and contractors to complete regular cybersecurity awareness and training programs to strengthen knowledge and reduce human error.

### **EM-01 Email Security**

This policy defines the controls for safeguarding SnowBe Online's email communications, including phishing prevention, encryption, and the safe handling of attachments.

### **FW-01 Firewall**

This policy outlines how SnowBe Online configures, manages, and monitors firewalls to protect network boundaries, control traffic, and prevent unauthorized access to company systems.

### **IA-02 Identification and Authentication (Organizational Users)**

Requires all SnowBe organizational users to authenticate before being able to access systems, applications, or data. This includes stronger password enforcement and MFA.



### **IA-05 Authenticator Management**

Helps SnowBe centralize password policies, rotation, history, protection of authenticators, and controlled self-service reset to curb weak or reused secrets.

### **MDM-01 Mobile Device Management**

This policy outlines the requirements for securing mobile devices that access SnowBe Online's systems to prevent data loss or unauthorized access.

### **MP-06 Media Sanitization**

Laptops, desktops, store devices, and any removable media must be securely wiped or destroyed before reuse/disposal to avoid data leakage.

### **PC-01 PCI DSS**

This policy defines how SnowBe Online protects cardholder data through encryption, network segmentation, continuous monitoring, and vendor oversight to ensure secure payment processing.

### **PW-01 Password Management**

This policy establishes SnowBe Online's requirements for creating, storing, and managing strong passwords, including complexity and expiration.

### **RA-01 Remote Access**

This policy defines the security requirements for securely connecting to SnowBe Online's internal systems remotely while protecting the company data from unauthorized access.

### **RAM-01 Risk Assessment and Management**

This policy establishes a structured process for identifying, evaluating, and mitigating risks to SnowBe Online's systems to ensure proactive protection and continuous compliance with security standards.

### **SC-04 Information in Shared System Resources**

This ensures that sensitive data isn't exposed via shared memory, caches, or logs. It helps avoid data remanence and cross-tenant leakage.

### **SC-07 Boundary Protection**

Internet-facing web tiers, store connectivity, and VPN entry points need layered firewalls, segmentation, and egress rules to reduce the attack surface and contain breaches.

### **SC-13 Cryptographic Protection**

Apply FIPS-validated or industry-approved cryptography everywhere required to reduce risk.

### **SC-28 Protection of Information at Rest**

Encrypt customer/PCI data at rest across on-premises storage, endpoint drives, and backups.

### **SI-07 Software, Firmware, and Information Integrity**

Use code signing, integrity checks, and tamper detection for web apps, updates, and critical images to prevent supply-chain tampering.

### **SM-01 Security Maturity Policy**

Defines how SnowBe Online measures, evaluates, and improves its security capabilities over time to ensure continuous alignment with risk, business needs, and industry standards.

### **SPM-01 Software Patch Management Policy**

Establishes the process for identifying, prioritizing, testing, and deploying software patches to reduce vulnerabilities and maintain secure and reliable systems.

### **SR-12 Component Disposal**

When retiring servers, POS terminals, or storage, use controlled destruction/verification so sensitive remnants aren't exposed.

### **VM-01 Vulnerability Management**

This policy defines how SnowBe Online identifies, prioritizes, and remediates vulnerabilities across its systems to reduce security risks and maintain compliance.

### **VMN-01 – Vendor Management**

This policy defines how SnowBe Online evaluates, approves, and monitors third-party vendors to ensure they meet security, privacy, and compliance requirements.

## **Standards and Procedures**

### **ACP-03 New Account Creation Procedure**

Establishes the authorized, repeatable workflow for creating new SnowBe user and service accounts, ensuring proper identity verification and role-appropriate access.

### **LPP-04 Linux Password Procedure**

Outlines steps for changing, resetting, and maintaining passwords on approved Linux systems.

### **PWS-04 Password Standard**

The Password Standard defines the minimum-security requirements for creating, managing, and protecting all passwords used across SnowBe systems.

### **WPP-04 Windows Password Procedure**

Provides step-by-step instructions for creating, changing, resetting, and securely managing passwords within SnowBe's Windows systems.

## Section 6: Exceptions/Exemptions

Requests for exceptions must be submitted in writing to SnowBe Online's IT Security Manager for review and approval. Each request must include the business justification, defined scope, duration, and any compensating controls that will be applied. All approved exceptions will be formally documented, reviewed periodically for continued appropriateness, and remain valid for no longer than one year unless re-evaluated and re-approved.

## Section 7: Version History Table

| Version | Date       | Description               |
|---------|------------|---------------------------|
| 1.0     | 11/3/2025  | Original Draft            |
| 2.0     | 11/10/2025 | Added Access Controls     |
| 3.0     | 11/17/2025 | Added Encryption Controls |
| 4.0     | 03/29/2026 | Added Various Policies    |

## Citations

Howard University - [https://technology.howard.edu/sites/technology.howard.edu/files/2020-03/Information\\_Security\\_Plan\\_0.pdf](https://technology.howard.edu/sites/technology.howard.edu/files/2020-03/Information_Security_Plan_0.pdf) (Used for Introduction, Scope, Exceptions/Exemptions).

Motlow State Community College - <https://www.motlow.edu/documents/information-security-plan.pdf> (Used for Definition, Statement of Policies, Standards, and Procedures).

University of Tennessee Knoxville - <https://oit.utk.edu/wp-content/uploads/2015-11-11-utk-sec-prog-plan.pdf> (Used for Roles & Responsibilities).